

Zero Trust Architecture Sandbox: Implementation and Evaluation Report

Minsoo Ahn

CSE 487 T92

Student ID: 114743792

Instructor: Antonino Mione

May 11, 2026

Abstract—This report describes a hands-on implementation of a Zero Trust Architecture (ZTA) using an open-source stack on a local Kubernetes cluster. The system follows NIST SP 800-207 [1] principles with Istio as the policy enforcement point, OPA as the policy decision point, and Keycloak as the identity provider. Five security scenarios are validated: lateral movement defense, JWT forgery and tampering, context-based access control, JWT claim-based authorization, and device posture gating. All 18 test cases pass in end-to-end runs, and evidence is captured through automated test logs and OPA decision logs. Performance measurements show an average latency increase of 1.53 ms and a 22.3% throughput reduction under single-connection load tests. The results demonstrate that ZTA enforces per-request, context-aware authorization and workload identity controls that traditional firewalls and VPNs do not provide, while introducing a measurable but acceptable overhead for a security-focused environment.

I. INTRODUCTION

Modern breaches commonly follow a two-stage pattern: credential theft followed by lateral movement inside the network. Traditional perimeter controls such as firewalls and VPNs can block unauthenticated ingress but provide limited visibility and control for east-west traffic between workloads. Zero Trust Architecture changes the assumption from “trusted internal” to “verify every request” [1], [2]. This project implements a ZTA sandbox to validate that request-level identity and policy enforcement can block a set of representative attacks while remaining practical to operate on a small cluster.

II. METHODOLOGY

A. Environment and Stack

The sandbox runs on Minikube with Istio 1.28.3 for service mesh enforcement, OPA for policy evaluation, and Keycloak for JWT issuance. A simple Flask frontend and backend are deployed as separate services. Security policies are applied through Istio AuthorizationPolicy and PeerAuthentication resources, and Rego policies in OPA.

B. Policy Design

Four independent layers enforce access decisions:

- mTLS workload identity for pod-to-pod traffic.
- SPIFFE allowlist to restrict backend access to the frontend service account.
- JWT signature validation using Keycloak JWKS.

- Context-aware authorization in OPA (role, method, path, posture).

Figure 1 illustrates both the north-south and east-west enforcement flows.

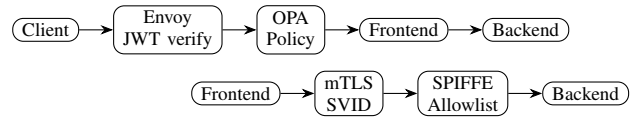


Fig. 1. Request flow and enforcement layers. Top row: north-south path (Client → Envoy JWT verify → OPA → Frontend → Backend). Bottom row: east-west path (Frontend → mTLS SVID → SPIFFE Allowlist → Backend).

C. Threat Model and Scenarios

Five scenarios are designed to represent realistic attack paths: (A) lateral movement, (B) JWT forgery and tampering, (C) context-based abuse, (D) role escalation through claims, and (E) device posture risk. Each scenario is mapped to a corresponding policy control and a reproducible test command.

D. Scenario Selection Rationale

The scenarios were chosen to reflect common attacker behavior observed in real microservice environments and to map cleanly to NIST SP 800-207 tenets. They are representative, repeatable on a local cluster, and span both north-south and east-west traffic paths without depending on rare or exotic conditions.

- A: Lateral movement is a dominant post-compromise behavior and validates workload identity plus service-to-service authorization.
- B: Forged or tampered JWTs are realistic API abuses and test cryptographic authentication at the infrastructure layer.
- C: Context abuse (method/path) reflects over-privileged access in practice and demonstrates fine-grained authorization beyond identity.
- D: Claim-based authorization closes header spoofing and validates signed identity as the policy source of truth.
- E: Device posture models access from risky or unmanaged devices, showing that identity alone is not sufficient.

III. RESULTS

A. Scenario Outcomes

All 18 test cases pass in the final validation run. Table I summarizes the scenario outcomes.

TABLE I
SECURITY SCENARIO OUTCOMES

Scenario	Threat and control	Result
A	Lateral movement blocked by mTLS and SPIFFE allowlist	Blocked
B	Forged or tampered JWT rejected by JWKS verification	Blocked
C	Role + method + path enforced in OPA policy	Enforced
D	JWT claim-based authorization with Keycloak + OPA	Enforced
E	Device posture gate via policy condition	Enforced

B. Scenario Details

A: Lateral movement (north-south and east-west). The north-south baseline confirms unauthenticated requests are denied, while a demo header allows access to illustrate why header-only identity is weak. For east-west movement, a rogue pod without a sidecar fails mTLS, and a pod with the wrong ServiceAccount is denied by the SPIFFE allowlist. Direct pod IP access is also blocked. These tests validate workload identity and service-to-service authorization as separate gates.

B: JWT forgery and tampering. A forged JWT is rejected because no valid principal is established at the mesh layer. A tampered payload with the original signature fails cryptographic verification, returning a 401. A valid Keycloak-issued JWT is accepted and passes to OPA for authorization.

C: Context-based access control. This scenario demonstrates that identity is not enough: role, method, and path must be consistent. A user role can read `/api/data` but is denied on `/api/admin` and all write operations, while an admin role can write. This uses header-based roles as a deliberate baseline for contrast with Scenario D. In the final configuration, JWT authentication is still enforced; the header-based rules illustrate why signed claims are needed even when a request is authenticated.

D: JWT claim authorization. Authorization is driven by signed claims in the JWT. An admin token can access admin endpoints, while a viewer token is limited to read-only paths. This closes header spoofing and demonstrates a cryptographically bound identity source of truth.

E: Device posture gating. Even with a valid admin JWT, access is denied when the device posture signal indicates risk. The demo uses the `X-Device-Firewall` header to model a health signal and illustrates how posture can be integrated into policy decisions.

Full test case results for all scenarios are shown in Table II.

TABLE II
COMBINED TEST MATRIX: ALL SCENARIOS A-E (18 CASES)

Scenario	Case	Request signals	Expect	Result
A	A-NS-1	GET <code>/api/admin</code> , no identity	403	403
	A-NS-2	GET <code>/api/admin</code> , header <code>role:admin</code>	200	200
	A-EW-1	Rogue pod (no sidecar) to backend service	403/000/503	403
	A-EW-2	Wrong ServiceAccount (backend-sa) to backend	403	403
B	A-EW-3	Rogue pod to backend pod IP:8080	403/000/503	503
	B-1	Forged JWT (invalid signature) to <code>/api/admin</code>	403	403
	B-2	Tampered real JWT payload to <code>/api/admin</code>	401	401
	B-3	Valid Keycloak JWT to <code>/api/admin</code>	200	200
C	C-1	<code>role:user</code> , GET <code>/api/data</code>	200	200
	C-2	<code>role:user</code> , GET <code>/api/admin</code>	403	403
	C-3	<code>role:user</code> , POST <code>/api/write</code>	403	403
	C-4	<code>role:admin</code> , POST <code>/api/write</code>	200	200
D	D-1	Admin JWT, GET <code>/api/admin</code>	200	200
	D-2	Viewer JWT, GET <code>/api/data</code>	200	200
	D-3	Viewer JWT, GET <code>/api/admin</code>	403	403
	D-4	Viewer JWT, POST <code>/api/write</code>	403	403
E	E-1	Admin JWT + <code>X-Device-Firewall: enabled</code>	200	200
	E-2	Admin JWT + <code>X-Device-Firewall: disabled</code>	403	403

C. Operational Evidence

OPA decision logs confirm allow and deny outcomes for each scenario, and the automated `make test-all` run provides a consolidated PASS summary. The evidence directory includes detailed logs for JWT forgery, lateral movement attempts, and device posture simulation. Figure 2 shows the Kiali workload graph confirming mTLS enforcement across active service paths.

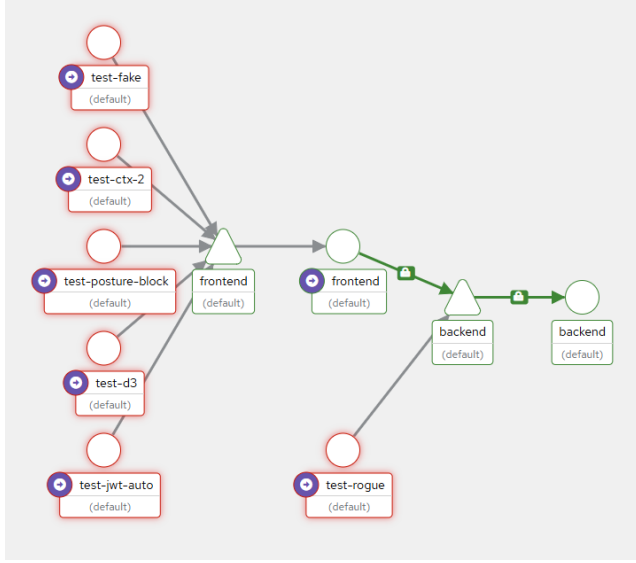


Fig. 2. Kiali Workload Graph captured during the `make for_pdf` test run, showing one representative request per scenario (A–E). The mTLS padlock icon on the frontend→backend edge confirms STRICT mutual authentication is active. Blocked paths (rogue pod, forged JWT) terminate at the ingress and do not appear as edges to the backend, illustrating that the enforcement layers are working as intended.

D. Performance

Performance testing uses Fortio with 200 requests and a single connection. Table III summarizes the aggregate overhead relative to a baseline with no Istio policies applied.

TABLE III
PERFORMANCE IMPACT (200 REQUESTS, SINGLE CONNECTION)

Metric	Baseline	ZTA	Delta
Avg latency	5.33 ms	6.86 ms	+1.53 ms (+28.6%)
QPS	187.5	145.7	−41.8 (−22.3%)
p99 latency	8.5 ms	10.5 ms	+2.0 ms (+23.5%)

Figure 3 visualizes the latency difference between baseline and ZTA.

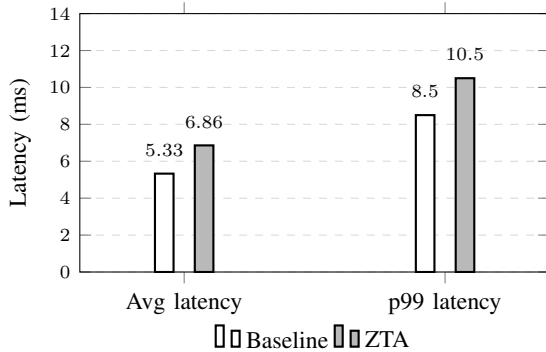


Fig. 3. Latency overhead introduced by ZTA policies (Fortio, 200 requests, single connection). QPS: baseline 187.5, ZTA 145.7 (−22.3%).

Table IV breaks down per-scenario timing. Blocked cases measure policy-gate cost only (the request is denied before

reaching the application), while allowed cases include full end-to-end handling; the two categories should be compared separately.

TABLE IV
PER-SCENARIO LATENCY (FORTIO, 200 REQUESTS): ALLOW CASES ARE END-TO-END; BLOCK CASES MEASURE POLICY GATE ONLY.

Case	Type	Request signal	Avg (ms)	p99 (ms)	Code
A1	Allow	Admin JWT, GET /api/admin	5.94	7.89	200
A2	Allow	Viewer JWT, GET /api/data	6.63	8.80	200
A3	Allow	role:user, GET /api/data	6.58	9.00	200
A4	Allow	Admin JWT + device firewall enabled	6.22	7.94	200
B1	Block	No identity, GET /api/admin	2.02	4.00	403
B2	Block	Forged JWT, GET /api/admin	2.36	5.00	403
B3	Block	Tampered JWT, GET /api/admin	2.00	4.00	401
B4	Block	Admin JWT + device firewall disabled	2.91	5.50	403

IV. DISCUSSION

A. Security Value vs Traditional Controls

The implementation demonstrates that per-request authorization at the infrastructure layer can block attack paths that traditional perimeter controls miss. Even with valid credentials, requests are denied when policy context is violated, and internal lateral movement is blocked by workload identity checks.

B. VPN vs ZTA

WireGuard [3] provides low-overhead transport security but does not enforce request-level authorization or workload identity. ZTA adds these controls with a measurable overhead, so the most practical deployment is layered: VPN for secure entry and ZTA for service policy enforcement.

V. LIMITATIONS

Device posture is simulated through a client-provided header, and the OPA ext-authz channel is not mTLS-encrypted due to sidecar dependency constraints. Header-based role rules remain in place to demonstrate weaker access controls (Scenario C) alongside the stronger JWT claim path (Scenario D). The scenario set is representative but not exhaustive, and ZTA does not eliminate risks from human error, misconfiguration, or novel low-level exploits. The environment is local and does not represent production-scale latency or throughput.

VI. EXPERIENCE AND REFLECTION

A. *Unexpected Outcomes*

I expected the implementation to be harder, but the core ZTA flow was manageable once the stack was aligned. The most surprising result was performance overhead: the latency increase and QPS drop were higher than I anticipated, even in a small test.

B. *Implementation Challenges*

The initial setup and integration of Istio, OPA, and Keycloak was the most time-consuming part. JWT verification flow and automated end-to-end tests required careful ordering and debugging. I also spent time looking for missing scenarios and thinking about bypasses not captured by the default test set.

C. *Limits of ZTA and Current Practice*

This project reinforced that ZTA is a strong practical approach but not perfect. It does not eliminate risks from human error, system misconfiguration, or novel low-level exploits, and it only blocks the scenarios it explicitly models. AI-assisted work helped accelerate policy iteration, but it did not remove the need for manual validation, and it reminded me that attackers can also use AI to discover new paths. ZTA feels like the best available option today, not a final solution.

D. *Lessons Learned and Future Work*

I learned that layered controls matter more than any single tool, and that the security-performance trade-off is real. As hardware improves, some overhead will be easier to absorb, but the dilemma remains. If I extend this work, I want to design a more efficient policy path and push enforcement closer to lower-level boundaries so that isolation holds even against unexpected paths.

VII. CONCLUSION

The sandbox validates that open-source tools can implement a realistic Zero Trust Architecture aligned with NIST SP 800-207 [1]. The system blocks five representative attack scenarios and provides clear audit evidence for each decision. The measured performance cost is acceptable for a security-focused environment, and the design illustrates how identity, context, and workload trust can replace implicit network trust.

REFERENCES

- [1] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," National Institute of Standards and Technology, Gaithersburg, MD, NIST SP 800-207, Aug. 2020. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-207>
- [2] R. Ward and B. Beyer, "BeyondCorp: A New Approach to Enterprise Security," *login.*, vol. 39, no. 6, pp. 6–11, Dec. 2014. [Online]. Available: <https://research.google/pubs/pub43231/>
- [3] J. A. Donenfeld, "WireGuard: Next Generation Kernel Network Tunnel," in *Proc. Network and Distributed System Security Symp. (NDSS)*, San Diego, CA, USA, Feb. 2017. [Online]. Available: <https://www.wireguard.com/papers/wireguard.pdf>